

De la vulnerabilidad al riesgo

OpenVAS · MAGERIT · MITRE ATT&CK · cálculo del riesgo

Módulo: Incidentes de Ciberseguridad · RA1

Objetivo: Aprender a transformar un hallazgo técnico de OpenVAS en un escenario de amenaza justificable, relacionarlo con MAGERIT y MITRE ATT&CK, estimar su riesgo y proponer medidas preventivas.

Caso conductor: CVE-2015-3306 — ProFTPD mod_copy. Se utilizará como ejemplo para recorrer todo el proceso.

Material complementario: Excel de ejemplos de Impacto y Probabilidad (25 + 25 casos).

Contenido

- 1. Qué estamos haciendo y por qué
- 2. Conceptos clave: vulnerabilidad, amenaza, técnica y riesgo
- 3. Flujo de trabajo completo
- 4. Paso 1: interpretar el hallazgo de OpenVAS
- 5. Paso 2: pasar de la vulnerabilidad a una amenaza MAGERIT
- 6. Papel de ENISA en el análisis
- 7. Paso 3: buscar la técnica en MITRE ATT&CK
- 8. Paso 4: calcular y clasificar el riesgo
- 9. Ejemplo completo: CVE-2015-3306
- 10. Segundo ejemplo: credenciales predeterminadas SSH
- 11. De la valoración del riesgo al plan de prevención (RA1)
- 12. Ficha de trabajo para el alumnado
- Anexo A. Tabla MAGERIT - ENISA
- Anexo B. 25 ejemplos de Impacto
- Anexo C. 25 ejemplos de Probabilidad
- Fuentes de consulta

1. Qué estamos haciendo y por qué

Un escáner de vulnerabilidades como OpenVAS identifica debilidades técnicas, pero el objetivo del análisis de riesgos no es limitarse a copiar un CVE o una puntuación CVSS. El trabajo profesional consiste en interpretar qué puede ocurrir sobre los activos de la organización, qué comportamiento podría realizar un atacante y qué prioridad debe darse al tratamiento del riesgo.

Idea fundamental: CVSS mide la gravedad técnica de una vulnerabilidad. No es, por sí solo, el riesgo de la organización.

2. Conceptos clave: vulnerabilidad, amenaza, técnica y riesgo

Concepto	Significado
Activo	Elemento que tiene valor para la organización: información, servidor, cuenta, servicio, aplicación, comunicaciones, etc.
Vulnerabilidad	Debilidad técnica, de configuración o de procedimiento que puede ser aprovechada.
Amenaza	Suceso o acción que puede causar daño a un activo. En esta guía se clasifica usando el catálogo de MAGERIT.
Táctica MITRE	Objetivo del adversario: el “para qué”. Ejemplo: Initial Access.
Técnica MITRE	Forma de actuar del adversario: el “cómo”. Ejemplo: T1190 Exploit Public-Facing Application.
Impacto	Gravedad de las consecuencias si la amenaza se materializa.
Probabilidad	Posibilidad de que el escenario de amenaza llegue a materializarse en el entorno concreto.
Riesgo	Prioridad resultante de combinar impacto y probabilidad en el modelo didáctico 5×5 de esta práctica.

3. Flujo de trabajo completo

1. OpenVAS: identificar la vulnerabilidad y leer qué permite técnicamente.
2. Activo: identificar qué elemento puede verse afectado.
3. Consecuencia: explicar qué le ocurriría al activo si se aprovecha la vulnerabilidad.
4. MAGERIT: seleccionar la amenaza que mejor represente esa consecuencia y justificarla.
5. MITRE ATT&CK: identificar, si procede, la táctica y técnica que describen el comportamiento del adversario.
6. Riesgo: valorar Impacto (1–5) y Probabilidad (1–5), calcular $I \times P$ y clasificar el resultado.
7. Prevención: definir medidas que reduzcan la probabilidad y/o el impacto y verificar después su eficacia.

Regla de trazabilidad: Cada conclusión debe poder justificarse: hallazgo → capacidad técnica → activo → consecuencia → amenaza → técnica → riesgo → medida.

4. Paso 1: interpretar el hallazgo de OpenVAS

Para cada vulnerabilidad detectada por OpenVAS:

8. Explica qué permite hacer técnicamente.
9. Identifica el activo que podría resultar afectado.
10. Explica qué consecuencia tendría sobre dicho activo.

11. Busca en MAGERIT la amenaza que mejor represente esa consecuencia.
12. Justifica la elección.
13. Busca, si procede, una técnica MITRE ATT&CK que describa el comportamiento utilizado para materializarla.

4.1. Caso conductor: CVE-2015-3306

OpenVAS detecta una vulnerabilidad crítica en ProFTPD mod_copy. El informe indica que el objetivo es vulnerable, que el módulo permite copia de archivos mediante SITE CPFR/CPTO sin autenticación y que, bajo determinadas circunstancias, puede producir ejecución remota de código.

2.1.1 Critical 21/tcp

Critical (CVSS: 10.0)
NVT: ProFTPD 'mod_copy' Unauthenticated Copying Of Files Via SITE CPFR/CPTO Vulnerability (Apr 2015) - Active Check
Summary
...continues on next page ...

2 RESULTS PER HOST

3

...continued from previous page ...
ProFTPD is prone to an unauthenticated copying of files vulnerability.
Quality of Detection (QoD): 99%
Vulnerability Detection Result The target was found to be vulnerable
Impact Under some circumstances this could result in remote code execution.
Solution: Solution type: VendorFix Ask the vendor for an update.
Vulnerability Detection Method Tries to copy /etc/passwd to /tmp/passwd.copy with SITE CPFR/CPTO command. Details: ProFTPD 'mod_copy' Unauthenticated Copying Of Files Via SITE CPFR/CPTO Vulnerab. ↔ OID:1.3.6.1.4.1.25623.1.0.105254 Version used: 2025-03-17T05:57:28Z
References cve: CVE-2015-3306 url: http://bugs.proftpd.org/show_bug.cgi?id=4169 cert-bund: CB-K15/0791 cert-bund: CB-K15/0791

Figura 1. Hallazgo de OpenVAS para ProFTPD mod_copy / CVE-2015-3306.

4.2. Verificar y comprender el CVE

Cuando exista un identificador CVE, conviene consultar una fuente de referencia como NVD para comprender exactamente la debilidad. En el caso de CVE-2015-3306, la descripción indica que mod_copy de ProFTPD 1.3.5 permite a atacantes remotos leer y escribir archivos arbitrarios mediante los comandos SITE CPFR y SITE CPTO.

Figura 2. Consulta del CVE-2015-3306 en NVD.

No confundir: La descripción del CVE/OpenVAS aporta la capacidad técnica. La etiqueta de amenaza MAGERIT se obtiene después, interpretando qué consecuencia tendría sobre un activo.

5. Paso 2: pasar de la vulnerabilidad a una amenaza MAGERIT

MAGERIT no contiene frases técnicas como “copiar archivos sin autenticación”. Su catálogo formula amenazas a un nivel más abstracto. Por eso no se busca literalmente la acción del exploit: se analiza qué le ocurriría al activo.

Pregunta guía: Si un atacante aprovecha esta vulnerabilidad, ¿qué puede ocurrirle al activo que quiero proteger?

Consecuencia sobre el activo	Amenaza MAGERIT	Cuándo elegirla
Acceso a recursos del sistema sin autorización	[A.11] Acceso no autorizado	Cuando la explotación permite entrar o utilizar recursos para los que el atacante no está autorizado.
Alteración intencionada de datos o ficheros	[A.15] Modificación deliberada de la información	Cuando el efecto relevante es cambiar el contenido o configuración.

Consecuencia sobre el activo	Amenaza MAGERIT	Cuándo elegirla
Eliminación de datos o ficheros	[A.18] Destrucción de información	Cuando el escenario contempla pérdida o borrado deliberado.
Obtención de información que no debería conocer	[A.19] Divulgación / revelación de información	Cuando la explotación permite leer, copiar o exponer información protegida.

5.1. Aplicación a ProFTPD

Paso	CVE-2015-3306 / ProFTPD
Hallazgo	CVE-2015-3306 / mod_copy
Fuente	OpenVAS + verificación del CVE
Capacidad técnica	Leer/copiar/escribir ficheros sin autenticación; potencial compromiso del sistema
Activo afectado	Datos / sistema / servicio FTP
Consecuencia posible	Acceder, copiar, modificar, incorporar o eliminar archivos, según el escenario
Amenaza MAGERIT	Depende de la consecuencia concreta sobre el activo
Si accede al sistema	[A.11] Acceso no autorizado
Si modifica datos	[A.15] Modificación deliberada de la información
Si obtiene información	[A.19] Divulgación / revelación de información
Si elimina información	[A.18] Destrucción de información

6. Papel de ENISA en el análisis

ENISA no es necesario para asignar una amenaza a cada CVE. Su Threat Landscape aporta contexto externo y actualidad: muestra qué tipos de amenazas, vectores y tendencias se observan en incidentes reales. Por tanto, ENISA es más útil después de analizar varias vulnerabilidades, para contrastar y contextualizar el conjunto de riesgos.

Uso recomendado en esta práctica: No obligar a buscar una categoría ENISA para cada CVE. Utilizar ENISA para responder: “¿Cuáles de nuestros vectores y amenazas tienen relevancia en el panorama real actual?”

La correspondencia MAGERIT-ENISA que se incluye en el Anexo A es orientativa. No existe una equivalencia oficial uno a uno entre ambas taxonomías.

7. Paso 3: buscar la técnica en MITRE ATT&CK

Principio: En MITRE ATT&CK no buscamos el CVE como tal; buscamos el comportamiento que tendría el adversario al aprovecharlo.

MITRE ATT&CK organiza el comportamiento adversario en tácticas y técnicas:

- Táctica = PARA QUÉ actúa el adversario (objetivo).
- Técnica = CÓMO intenta conseguir ese objetivo.

7.1. Método de búsqueda

Paso	Pregunta	Ejemplo
Pregunta 1	¿Qué podría hacer el atacante aprovechando la vulnerabilidad?	Ejemplo: explotar remotamente un servicio FTP vulnerable.
Pregunta 2	¿Para qué lo hace?	Ejemplo: para entrar o comprometer inicialmente el sistema → táctica Initial Access.
Pregunta 3	¿Cómo lo hace?	Ejemplo: explotando una vulnerabilidad de un servicio expuesto → buscar técnicas relacionadas con exploit / public-facing / vulnerability.

Para CVE-2015-3306, si ProFTPD está expuesto al atacante y la explotación se utiliza para obtener acceso inicial, el comportamiento puede encajar en:

MITRE ATT&CK: T1190 — Exploit Public-Facing Application · Táctica: Initial Access.

7.2. Qué revisar al abrir una técnica

Campo MITRE	Qué comprobar
ID	Código de la técnica. Ej.: T1190.
Name	Nombre oficial de la técnica.
Tactic	Objetivo del adversario asociado.
Description	Comprobar que la descripción coincide realmente con el escenario.
Platforms	Comprobar que la técnica es aplicable a la plataforma.
Procedure Examples	Ejemplos reales de uso por grupos o software.
Mitigations	Medidas que pueden reducir el riesgo.
Detection Strategy / Detection	Indicaciones para detectar el comportamiento.

Importante: Una vulnerabilidad no tiene necesariamente una única técnica MITRE. La técnica se asigna al comportamiento y al escenario, no al CVE de forma automática.

8. Paso 4: calcular y clasificar el riesgo

MAGERIT completo trabaja con la valoración de activos, degradación, impacto y frecuencia. Para esta actividad de FP utilizaremos una adaptación didáctica 5×5 más fácil de aplicar y justificar:

Fórmula de la práctica: $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$

Impacto y Probabilidad se valoran de 1 a 5. Por tanto, el resultado está entre 1 y 25. Este modelo facilita comparar y priorizar escenarios, pero no debe presentarse como la única fórmula oficial de MAGERIT.

Valor	Impacto	Probabilidad
1	Insignificante	Muy improbable
2	Bajo	Poco probable

Valor	Impacto	Probabilidad
3	Medio	Posible
4	Alto	Probable
5	Muy alto / crítico	Muy probable

8.1. Cómo justificar el Impacto

El impacto depende del activo y de las consecuencias que tendría la amenaza, no de la puntuación CVSS. Para justificarlo, se analizan las dimensiones de seguridad y el daño operativo, económico, legal o reputacional.

- Confidencialidad: ¿qué ocurre si la información se revela?
- Integridad: ¿qué ocurre si los datos se modifican?
- Disponibilidad: ¿qué ocurre si el servicio deja de estar disponible?
- Autenticidad: ¿qué ocurre si no podemos garantizar quién ha realizado una acción?
- Trazabilidad: ¿qué ocurre si no podemos reconstruir lo sucedido?

8.2. Cómo justificar la Probabilidad

La probabilidad debe estimarse sobre el entorno concreto. Se deben considerar, entre otros, los siguientes factores:

- ¿Está el servicio activo y accesible?
- ¿Está expuesto a Internet o solo a una red interna?
- ¿Requiere autenticación?
- ¿Existe exploit público o automatizado?
- ¿Qué dificultad técnica tiene la explotación?
- ¿Hay firewall, segmentación, WAF, MFA u otros controles compensatorios?
- ¿Existe evidencia de intentos de explotación?
- ¿Cuánto tiempo lleva el sistema sin parchear?

Conclusión: La misma vulnerabilidad puede tener distinto riesgo en organizaciones distintas porque cambian el valor del activo, la exposición y los controles existentes.

8.3. Tabla de cálculo y clasificación

Resultado I×P	Nivel	Interpretación	Prioridad orientativa
1-4	Bajo	Consecuencias y/o probabilidad reducidas.	Planificar / aceptar si está justificado.
5-9	Medio	Requiere control y seguimiento.	Tratar de forma programada.
10-16	Alto	Puede causar un daño significativo.	Prioridad alta.
17-25	Crítico	Daño grave y escenario plausible.	Actuación prioritaria e inmediata.

8.4. Matriz 5×5

P\I	1	2	3	4	5
1	1 Bajo	2 Bajo	3 Bajo	4 Bajo	5 Medio

2	2 Bajo	4 Bajo	6 Medio	8 Medio	10 Alto
3	3 Bajo	6 Medio	9 Medio	12 Alto	15 Alto
4	4 Bajo	8 Medio	12 Alto	16 Alto	20 Crítico
5	5 Medio	10 Alto	15 Alto	20 Crítico	25 Crítico

9. Ejemplo completo: CVE-2015-3306

Elemento	Análisis
Vulnerabilidad	CVE-2015-3306 — ProFTPD mod_copy.
Qué permite técnicamente	Lectura/escritura/copia de archivos mediante SITE CPFR/CPTO sin autenticación; potencial compromiso del sistema.
Activo elegido	Ficheros y configuración del servidor FTP.
Consecuencia analizada	Modificación no autorizada de información crítica.
Amenaza MAGERIT	[A.15] Modificación deliberada de la información.
Táctica MITRE	Initial Access, si se usa para obtener acceso inicial.
Técnica MITRE	T1190 — Exploit Public-Facing Application, si el servicio está expuesto y el escenario coincide.
Impacto	5 — Muy alto: modificar ficheros/configuración críticos puede comprometer la integridad del servidor y del servicio.
Probabilidad	4 — Probable: vulnerabilidad confirmada, servicio accesible por red y explotación sin autenticación. Si estuviera publicado directamente en Internet y existiera explotación automatizada, podría justificarse 5.
Cálculo	$5 \times 4 = 20$.
Nivel	Crítico.
Medidas	Actualizar/corregir ProFTPD, deshabilitar mod_copy si no se necesita, reducir la exposición del FTP, segmentar, aplicar mínimo privilegio y volver a escanear.

10. Segundo ejemplo: credenciales predeterminadas SSH

Elemento	Análisis
Hallazgo	OpenVAS comprueba que es posible autenticarse mediante vagrant:vagrant.
Vulnerabilidad	Credenciales predeterminadas / conocidas.
Activo	Servidor y cuenta de usuario.
Consecuencia	Un usuario no autorizado puede autenticarse y acceder a recursos.
Amenaza MAGERIT	[A.11] Acceso no autorizado.
MITRE ATT&CK	T1078.001 — Valid Accounts: Default Accounts.

Elemento	Análisis
Prevención	Eliminar o cambiar credenciales predeterminadas, restringir acceso SSH, preferir claves, MFA cuando proceda y monitorizar autenticaciones.

11. De la valoración del riesgo al plan de prevención (RA1)

El cálculo del riesgo no es el final. Su función es priorizar el tratamiento y justificar qué normas y salvaguardas deben implantarse. Esto conecta directamente con el RA1: desarrollar planes de prevención y concienciación estableciendo normas y medidas de protección.

Resultado del análisis	Decisión preventiva	Ejemplo
Riesgo crítico/alto	Reducir de forma prioritaria	Parchear, deshabilitar servicio vulnerable, segmentar, restringir puertos.
Riesgo medio	Reducir y monitorizar	Aplicar hardening, programar actualización, reforzar registro y alertas.
Riesgo bajo	Aceptar justificadamente o mejorar cuando sea viable	Documentar aceptación y mantener controles.
Tras aplicar medidas	Reevaluar	Repetir OpenVAS y recalcular el riesgo residual.

Ciclo de auditoría: OpenVAS inicial → análisis de amenazas → valoración del riesgo → medidas de hardening → nuevo OpenVAS → comparación → riesgo residual.

12. Ficha de trabajo para el alumnado

Completa una ficha por vulnerabilidad. La justificación es obligatoria; no se aceptan valores numéricos sin razonamiento.

Campo	Respuesta
1. Hallazgo OpenVAS	
2. CVE / referencia	
3. Qué permite técnicamente	
4. Activo afectado	
5. Consecuencia sobre el activo	
6. Amenaza MAGERIT + justificación	
7. Táctica MITRE (para qué)	
8. Técnica MITRE (cómo) + justificación	

Campo	Respuesta
9. Impacto (1-5) + justificación	
10. Probabilidad (1-5) + justificación	
11. Riesgo = $I \times P$	
12. Nivel de riesgo	
13. Medidas preventivas	
14. Riesgo residual tras las medidas	

Anexo A. Tabla orientativa MAGERIT - ENISA

Esta tabla sirve como referencia contextual. No existe una equivalencia oficial uno a uno entre MAGERIT y ENISA Threat Landscape.

Código MAGERIT	Amenaza MAGERIT	Contexto ENISA más próximo	Correspondencia
[A.11]	Acceso no autorizado	Unauthorised access	Muy directa
[A.24]	Denegación de servicio	DDoS / Denial of Service	Muy directa
[A.30]	Ingeniería social (picaresca)	Social engineering / Phishing / Smishing / ClickFix	Muy directa
[A.5]	Suplantación de la identidad del usuario	Fraud and Impersonation	Muy directa
[A.19]	Divulgación de información	Data breaches / Data exposure	Muy directa
[A.29]	Extorsión	Ransomware / Extortion	Muy directa
[A.8]	Difusión de software dañino	Malware / Ransomware / Infostealers	Directa
[A.14]	Interceptación de información (escucha)	Interception / Credential or data theft in intrusion operations	Parcial / directa según incidente
[A.6]	Abuso de privilegios de acceso	Insider threats / Credential compromise	Parcial
[A.22]	Manipulación de programas	Software compromise / Supply-chain attack	Muy próxima
[A.15]	Modificación deliberada de la información	Contextos de compromiso/manipulación de sistemas	Próxima / contextual
[A.18]	Destrucción de información	Destructive attacks / destructive ransomware	Próxima
[A.26]	Ataque destructivo	Destructive attacks / State-nexus operations	Próxima
[E.20]	Vulnerabilidades de los programas (software)	Exploitation of vulnerabilities: N-day / 0-day	Muy directa como vector
[E.4]	Errores de configuración	Misconfiguration / Accidental exposure	Muy directa
[E.19]	Fugas de información	Data breaches / Accidental exposure	Directa
[E.8]	Difusión de software dañino	Malware introduced accidentally	Parcial
[E.21]	Errores de mantenimiento / actualización de software	Unpatched systems → vulnerability exploitation	Próxima
[I.8]	Fallo de servicios de comunicaciones	Puede causar indisponibilidad	Sin equivalencia directa
[I.6]	Corte del suministro eléctrico	No es una amenaza cibernética principal del ETL	Sin equivalencia directa
[N.1]	Fuego	No tratado como categoría de ciberamenaza	Sin equivalencia directa
[N.2]	Daños por agua	No tratado como categoría de ciberamenaza	Sin equivalencia directa

Anexo B. Ejemplos para valorar el Impacto

Cinco ejemplos por cada nivel. El valor debe justificarse siempre según el activo concreto y las consecuencias para la organización.

Nivel	Clasificación	Ejemplo	Por qué se asigna este valor
1	Insignificante	Borrado accidental de un archivo temporal generado por una aplicación.	Puede regenerarse automáticamente y no afecta al servicio ni a los usuarios.
1	Insignificante	Caída durante unos segundos de una página interna de pruebas.	No presta un servicio productivo y la interrupción apenas tiene consecuencias.
1	Insignificante	Modificación de un documento de ejemplo sin información real.	No tiene valor operativo, legal ni económico y puede restaurarse fácilmente.
1	Insignificante	Exposición del nombre de versión de un software sin otros datos sensibles.	La información revelada tiene escaso valor por sí sola y no causa daño directo.
1	Insignificante	Bloqueo de una cuenta de laboratorio que puede restablecerse inmediatamente.	La cuenta no es crítica y la recuperación es inmediata.
2	Bajo	Pérdida de apuntes internos recuperables desde una copia reciente.	Existe copia de seguridad y el trabajo de recuperación es pequeño.
2	Bajo	Indisponibilidad de una impresora de red durante una hora.	Interrumpe una función auxiliar, pero existen alternativas.
2	Bajo	Acceso no autorizado a un directorio con manuales internos no sensibles.	La información no es pública, pero su revelación tendría consecuencias limitadas.
2	Bajo	Alteración de la configuración visual de una intranet sin afectar a los datos.	La aplicación sigue funcionando y el cambio puede corregirse rápidamente.
2	Bajo	Pérdida temporal de acceso de un usuario no crítico.	Afecta a una sola persona y puede resolverse con poco tiempo y coste.
3	Medio	Caída del servidor de archivos de un departamento durante varias horas.	Afecta a varios usuarios y genera retrasos, aunque la actividad puede continuar parcialmente.
3	Medio	Divulgación de datos internos de empleados sin información especialmente sensible.	Existe impacto organizativo, pero el daño no paraliza la actividad.
3	Medio	Modificación de registros de una aplicación que obliga a restaurar una copia.	Requiere intervención técnica y puede provocar pérdida limitada de trabajo reciente.
3	Medio	Compromiso de una cuenta con permisos estándar.	Permite acceder a recursos del usuario, pero no tiene privilegios administrativos.
3	Medio	Malware en un equipo de usuario que obliga a aislarlo y reinstalarlo.	Se pierde productividad, pero el incidente queda contenido en un equipo.
4	Alto	Caída de un servidor web corporativo durante una jornada laboral.	Afecta a numerosos usuarios o clientes y provoca una interrupción relevante.
4	Alto	Robo de credenciales de una cuenta con privilegios elevados.	Permite acceder a múltiples recursos y facilita comprometer otros activos.
4	Alto	Modificación no autorizada de datos de facturación.	Puede generar errores económicos, reclamaciones y revisión extensa de datos.
4	Alto	Exposición de información personal de un número importante de usuarios.	Puede generar obligaciones legales, comunicaciones y daño reputacional.
4	Alto	Borrado de parte importante de un repositorio compartido, recuperable desde backup.	La recuperación es posible, pero implica interrupción y posible pérdida de cambios recientes.
5	Muy alto / crítico	Ransomware que cifra servidores de producción y copias de seguridad accesibles.	Puede paralizar la organización durante días y comprometer la recuperación.
5	Muy alto / crítico	Compromiso de una cuenta de administrador de dominio.	El atacante podría controlar gran parte de la infraestructura.

Nivel	Clasificación	Ejemplo	Por qué se asigna este valor
5	Muy alto / crítico	Alteración de una base de datos crítica sin poder determinar qué registros cambiaron.	Se pierde la confianza en la información y puede requerir reconstrucción completa.
5	Muy alto / crítico	Filtración masiva de datos personales o secretos empresariales.	Puede provocar sanciones, perjuicios económicos graves y daño reputacional duradero.
5	Muy alto / crítico	Ataque que deja indisponible un servicio esencial sin alternativa durante varios días.	La organización no puede prestar una función esencial.

Anexo C. Ejemplos para valorar la Probabilidad

Cinco ejemplos por cada nivel. La probabilidad depende del entorno real: exposición, controles, facilidad de explotación y evidencia disponible.

Nivel	Clasificación	Ejemplo de escenario	Por qué se asigna este valor
1	Muy improbable	Servicio vulnerable instalado, pero deshabilitado y sin proceso en ejecución.	No hay un servicio accesible que pueda ser atacado en condiciones normales.
1	Muy improbable	Vulnerabilidad explotable únicamente con acceso físico a un servidor en CPD controlado.	Requiere superar controles físicos fuertes y poco frecuentes.
1	Muy improbable	Aplicación antigua aislada en una VLAN sin acceso desde usuarios ni Internet.	La superficie de exposición es mínima y existen barreras de red importantes.
1	Muy improbable	Ataque que requiere una combinación específica de versiones que no coincide con el entorno.	Los prerrequisitos técnicos no están presentes.
1	Muy improbable	Cuenta deshabilitada que conserva una contraseña débil.	La debilidad no puede aprovecharse mientras la cuenta permanezca deshabilitada.
2	Poco probable	Servicio vulnerable accesible solo desde una red administrativa muy restringida.	Existe una ruta de ataque, pero requiere acceso previo a una red restringida.
2	Poco probable	Vulnerabilidad que requiere autenticación con cuenta válida y permisos específicos.	El atacante debe superar previamente otra barrera.
2	Poco probable	Servidor vulnerable protegido mediante firewall y lista blanca.	Los controles compensatorios reducen mucho la oportunidad de explotación.
2	Poco probable	Aplicación usada por un pequeño grupo interno y sin exposición a Internet.	La superficie de ataque es reducida.
2	Poco probable	Ingeniería social sobre personal formado y con MFA obligatorio.	La formación y el MFA reducen la probabilidad de éxito.
3	Posible	Servidor interno vulnerable accesible desde toda la LAN corporativa.	Existen numerosos posibles orígenes internos, aunque no está publicado en Internet.
3	Posible	Servicio web expuesto a Internet con vulnerabilidad conocida pero protegido por WAF.	Existe exposición, pero un control específico dificulta la explotación.
3	Posible	Contraseñas de complejidad media sin MFA en una aplicación remota.	El ataque es viable si se descubre o reutiliza una contraseña.
3	Posible	Equipo con macros permitidas, antivirus y filtrado de correo activos.	El vector existe, pero debe superar controles.
3	Posible	Software sin parchear durante varias semanas en un servicio habitual.	Hay una ventana real de explotación con exposición moderada.
4	Probable	Servicio vulnerable expuesto directamente a Internet y con exploit público.	La vulnerabilidad es accesible y existen herramientas que facilitan la explotación.
4	Probable	OpenVAS confirma una vulnerabilidad remota sin autenticación en un servicio activo.	La debilidad está presente y es alcanzable por red.
4	Probable	Cuenta remota sin MFA con contraseña reutilizada previamente filtrada.	El atacante dispone de una credencial utilizable y no hay segunda barrera.
4	Probable	Servidor web sin parchear y accesible públicamente durante meses.	El tiempo de exposición incrementa mucho la oportunidad de ataque.
4	Probable	Servicio FTP con credenciales débiles accesible desde múltiples redes.	Alta accesibilidad y autenticación débil hacen el escenario plausible.
5	Muy probable	Servicio expuesto a Internet con vulnerabilidad crítica sin autenticación y exploit automatizado.	Cualquier atacante puede intentarlo automáticamente con pocas barreras.
5	Muy probable	Credenciales por defecto activas en un servicio remoto publicado en Internet.	Las credenciales son conocidas y la explotación es trivial.

Nivel	Clasificación	Ejemplo de escenario	Por qué se asigna este valor
5	Muy probable	Sistema vulnerable con intentos de explotación ya observados en los registros.	Existe evidencia directa de ataques contra el activo.
5	Muy probable	Servidor con CVE explotada activamente y sin medidas compensatorias.	Existe evidencia externa de explotación frecuente y no hay barreras adicionales.
5	Muy probable	Aplicación accesible a todos los usuarios con función crítica sin autenticación.	La oportunidad de abuso es constante y no existe una barrera efectiva.

Fuentes de consulta

Fuente	Uso en la práctica
OpenVAS / Greenbone	Informe de vulnerabilidades utilizado en la práctica.
MAGERIT v3, Libro II — Catálogo de Elementos	Catálogo de amenazas para el análisis de riesgos.
MITRE ATT&CK Enterprise	https://attack.mitre.org/ — tácticas, técnicas, mitigaciones y detección.
NVD — National Vulnerability Database	https://nvd.nist.gov/ — información técnica y referencias de CVE.
ENISA Threat Landscape	Contexto de amenazas, vectores y tendencias actuales; no es una correspondencia 1:1 con MAGERIT.
Resumen final: OpenVAS descubre la debilidad. MAGERIT ayuda a expresar qué amenaza supone sobre los activos. MITRE ATT&CK describe cómo puede actuar el adversario. La matriz Impacto × Probabilidad prioriza el riesgo. Las medidas preventivas reducen ese riesgo y deben verificarse mediante una nueva auditoría.	